ZAP by Checkmarx Scanning Report

Generated with The ZAP logo **ZAP** on Tue 24 Feb 2026, at 15:00:34

ZAP Version: 2.17.0

ZAP by **Checkmarx**

Contents

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

```
http://altoro.testfire.net
```

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: **HIGH** , **MEDIUM** , **LOW** , **INFORMATIONAL**

Excluded: None

Confidence levels

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		CONFIDENCE				
		USER CONFIRMED	HIGH	MEDIUM	LOW	TOTAL
RISK	HIGH	0 (0.0%)	1 (6.2%)	0 (0.0%)	0 (0.0%)	1 (6.2%)
	MEDIUM	0 (0.0%)	1 (6.2%)	1 (6.2%)	1 (6.2%)	3 (18.8%)
	LOW	0 (0.0%)	2 (12.5%)	5 (31.2%)	0 (0.0%)	7 (43.8%)
	INFORMATIONAL	0 (0.0%)	0 (0.0%)	3 (18.8%)	2 (12.5%)	5 (31.2%)
	TOTAL	0 (0.0%)	4 (25.0%)	9 (56.2%)	3 (18.8%)	16 (100%)

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		RISK			
		HIGH (= HIGH)	MEDIUM (>= MEDIUM)	LOW (>= LOW)	INFORMATIONAL (>= INFORMATIONAL)
SITE	HTTP://ALTORO.TESTFIRE.NET	1 (1)	3 (4)	7 (11)	5 (16)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

ALERT TYPE	RISK	COUNT
PII DISCLOSURE	HIGH	6 (37.5%)
ABSENCE OF ANTI-CSRF TOKENS	MEDIUM	5 (31.2%)
CONTENT SECURITY POLICY (CSP) HEADER NOT SET	MEDIUM	5 (31.2%)
MISSING ANTI-CLICKJACKING HEADER	MEDIUM	5 (31.2%)
APPLICATION ERROR DISCLOSURE	LOW	1

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

ALERT TYPE	RISK	COUNT
		(6.2%)
COOKIE NO HTTPONLY FLAG	LOW	1 (6.2%)
COOKIE WITHOUT SAMESITE ATTRIBUTE	LOW	3 (18.8%)
IN PAGE BANNER INFORMATION LEAK	LOW	1 (6.2%)
INFORMATION DISCLOSURE - DEBUG ERROR MESSAGES	LOW	2 (12.5%)
SERVER LEAKS VERSION INFORMATION VIA "SERVER" HTTP RESPONSE HEADER FIELD	LOW	5 (31.2%)
X-CONTENT-TYPE-OPTIONS HEADER MISSING	LOW	5 (31.2%)
AUTHENTICATION REQUEST IDENTIFIED	INFORMATIONAL	1 (6.2%)
INFORMATION DISCLOSURE - SUSPICIOUS COMMENTS	INFORMATIONAL	5 (31.2%)
MODERN WEB APPLICATION	INFORMATIONAL	1 (6.2%)
SESSION MANAGEMENT RESPONSE IDENTIFIED	INFORMATIONAL	3 (18.8%)
USER CONTROLLABLE HTML ELEMENT ATTRIBUTE (POTENTIAL XSS)	INFORMATIONAL	6 (37.5%)
TOTAL		16

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

LEVEL	REASON	SITE	DESCRIPTION	STATISTIC
Info	Informational	http://altoro.testfire.net	Percentage of responses with status code 2xx	79 %
Info	Informational	http://altoro.testfire.net	Percentage of responses with status code 3xx	16 %
Info	Informational	http://altoro.testfire.net	Percentage of responses with status code 5xx	4 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with content type application/javascript	6 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with content type application/json	3 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with content type image/gif	6 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with content type image/jpeg	18 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with content type image/png	3 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with content type text/css	6 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with content type text/html	50 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with method GET	87 %
Info	Informational	http://altoro.testfire.net	Percentage of endpoints with method POST	12 %
Info	Informational	http://altoro.testfire.net	Count of total endpoints	32
Info	Informational	http://altoro.testfire.net	Percentage of slow responses	100 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of responses with status code 2xx	91 %

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

LEVEL	REASON	SITE	DESCRIPTION	STATISTIC
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of responses with status code 3xx	8 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of endpoints with content type font/woff2	16 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of endpoints with content type image/gif	6 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of endpoints with content type image/png	19 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of endpoints with content type image/svg+xml	29 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of endpoints with content type text/css	3 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of endpoints with content type text/javascript	25 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Count of total endpoints	31
Info	Informational	https://assets-prod.sumo.prod.webservices.mozgcp.net	Percentage of slow responses	42 %
Info	Informational	https://online.swagger.io	Percentage of responses with status code 3xx	100 %
Info	Informational	https://online.swagger.io	Percentage of endpoints with content type text/html	100 %
Info	Informational	https://online.swagger.io	Percentage of endpoints with method GET	100 %
Info	Informational	https://online.swagger.io	Count of total endpoints	1
Info	Informational	https://online.swagger.io	Percentage of slow responses	100 %

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

LEVEL	REASON	SITE	DESCRIPTION	STATISTIC
Info	Informational	https://support.mozilla.org	Percentage of responses with status code 2xx	71 %
Info	Informational	https://support.mozilla.org	Percentage of responses with status code 3xx	21 %
Info	Informational	https://support.mozilla.org	Percentage of responses with status code 4xx	7 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with content type application/font-woff2	10 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with content type application/javascript	10 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with content type application/json	20 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with content type text/css	10 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with content type text/html	40 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with content type text/plain	10 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with method GET	90 %
Info	Informational	https://support.mozilla.org	Percentage of endpoints with method POST	10 %
Info	Informational	https://support.mozilla.org	Count of total endpoints	10
Info	Informational	https://support.mozilla.org	Percentage of slow responses	85 %
Info	Informational	https://validator.swagger.io	Percentage of responses with status code 2xx	100 %
Info	Informational	https://validator.swagger.io	Percentage of endpoints with content type image/png	100 %

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

LEVEL	REASON	SITE	DESCRIPTION	STATISTIC
Info	Informational	https://validator.swagger.io	Percentage of endpoints with method GET	100 %
Info	Informational	https://validator.swagger.io	Count of total endpoints	1
Info	Informational	https://validator.swagger.io	Percentage of slow responses	100 %
Info	Informational	https://www.googletagmanager.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.googletagmanager.com	Percentage of endpoints with content type application/javascript	100 %
Info	Informational	https://www.googletagmanager.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://www.googletagmanager.com	Count of total endpoints	1
Info	Informational	https://www.googletagmanager.com	Percentage of slow responses	100 %

Alerts

1. **Risk= HIGH , Confidence= High (1)**
    1. `http://altoro.testfire.net` **(1)**
        1. **PII Disclosure** (1)
            1. ▶ GET http://altoro.testfire.net/bank/main.jsp
2. **Risk= MEDIUM , Confidence= High (1)**
    1. `http://altoro.testfire.net` **(1)**
        1. **Content Security Policy (CSP) Header Not Set** (1)
            1. ▶ GET http://altoro.testfire.net/

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

3. **Risk= MEDIUM , Confidence= Medium (1)**

    1. http://altoro.testfire.net (1)

        1. Missing Anti-clickjacking Header (1)

            1. ▶ GET http://altoro.testfire.net/

4. **Risk= MEDIUM , Confidence= Low (1)**

    1. http://altoro.testfire.net (1)

        1. Absence of Anti-CSRF Tokens (1)

            1. ▶ GET http://altoro.testfire.net/login.jsp

5. **Risk= LOW , Confidence= High (2)**

    1. http://altoro.testfire.net (2)

        1. In Page Banner Information Leak (1)

            1. ▶ POST http://altoro.testfire.net/bank/ccApply

        2. Server Leaks Version Information via "Server" HTTP Response Header Field (1)

            1. ▶ GET http://altoro.testfire.net/

6. **Risk= LOW , Confidence= Medium (5)**

    1. http://altoro.testfire.net (5)

        1. Application Error Disclosure (1)

            1. ▶ POST http://altoro.testfire.net/bank/ccApply

        2. Cookie No HttpOnly Flag (1)

            1. ▶ POST http://altoro.testfire.net/doLogin

        3. Cookie without SameSite Attribute (1)

            1. ▶ GET http://altoro.testfire.net/

        4. Information Disclosure - Debug Error Messages (1)

            1. ▶ GET http://altoro.testfire.net/swagger/properties.json

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

5. X-Content-Type-Options Header Missing (1)

1. ▶ GET http://altoro.testfire.net/

7. **Risk=** INFORMATIONAL **, Confidence=** Medium **(3)**

1. `http://altoro.testfire.net` **(3)**

1. Information Disclosure - Suspicious Comments (1)

1. ▶ GET http://altoro.testfire.net/login.jsp

2. Modern Web Application (1)

1. ▶ GET http://altoro.testfire.net/swagger/index.html

3. Session Management Response Identified (1)

1. ▶ GET http://altoro.testfire.net/

8. **Risk=** INFORMATIONAL **, Confidence=** Low **(2)**

1. `http://altoro.testfire.net` **(2)**

1. Authentication Request Identified (1)

1. ▶ POST http://altoro.testfire.net/admin/admin.jsp

2. User Controllable HTML Element Attribute (Potential XSS) (1)

1. ▶ GET http://altoro.testfire.net/bank/showAccount?listAccounts=800000

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

1. **PII Disclosure**

SOURCE	raised by a passive scanner (PII Disclosure)

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

CWE ID	359
WASC ID	13

2. **Absence of Anti-CSRF Tokens**

SOURCE	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352
WASC ID	9
REFERENCE	1. https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html 2. https://cwe.mitre.org/data/definitions/352.html

3. **Content Security Policy (CSP) Header Not Set**

SOURCE	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
REFERENCE	1. https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP 2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html 3. https://www.w3.org/TR/CSP/ 4. https://w3c.github.io/webappsec-csp/ 5. https://web.dev/articles/csp 6. https://caniuse.com/#feat=contentsecuritypolicy 7. https://content-security-policy.com/

4. **Missing Anti-clickjacking Header**

SOURCE	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
REFERENCE	1. https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

5. **Application Error Disclosure**

SOURCE	raised by a passive scanner (Application Error Disclosure)

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

CWE ID	550
WASC ID	13

6. **Cookie No HttpOnly Flag**

SOURCE	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13
REFERENCE	1. https://owasp.org/www-community/HttpOnly

7. **Cookie without SameSite Attribute**

SOURCE	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
REFERENCE	1. https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

8. **In Page Banner Information Leak**

SOURCE	raised by a passive scanner (In Page Banner Information Leak)
CWE ID	497
WASC ID	13
REFERENCE	1. https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

9. **Information Disclosure - Debug Error Messages**

SOURCE	raised by a passive scanner (Information Disclosure - Debug Error Messages)
CWE ID	1295
WASC ID	13

10. **Server Leaks Version Information via "Server" HTTP Response Header Field**

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

SOURCE	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
REFERENCE	1. https://httpd.apache.org/docs/current/mod/core.html#servertokens 2. https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) 3. https://www.troyhunt.com/shhh-dont-let-your-response-headers/

11. X-Content-Type-Options Header Missing

SOURCE	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
REFERENCE	1. https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) 2. https://owasp.org/www-community/Security_Headers

12. Authentication Request Identified

SOURCE	raised by a passive scanner (Authentication Request Identified)
REFERENCE	1. https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

13. Information Disclosure - Suspicious Comments

SOURCE	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

14. Modern Web Application

SOURCE	raised by a passive scanner (Modern Web Application)

15. Session Management Response Identified

SOURCE	raised by a passive scanner (Session Management Response Identified)

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

REFERENCE	1. https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

16. User Controllable HTML Element Attribute (Potential XSS)

SOURCE	raised by a passive scanner (User Controllable HTML Element Attribute (Potential XSS))
CWE ID	20
WASC ID	20
REFERENCE	1. https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html</

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF